Комплексная экспертная система поддержки аналитической деятельности в управлении безопасностью автоматизированных информационных систем «РискМенеджер»

Программный комплекс
«РискМенеджер-Анализ»

Общее описание

2003

АННОТАЦИЯ

Настоящий документ содержит общее описание программного комплекса «РискМенеджер-Анализ» Комплексной экспертной системы (КЭС) «РискМенеджер».

СОДЕРЖАНИЕ

Стр.

1. НАЗНАЧЕНИЕ ПРОГРАММЫ....4

2. ОПИСАНИЕ ПРОГРАММЫ....4

2.1. Базы данных ПК «РискМенеджер-Анализ»....4

2.2. Построение структурной модели с использованием системы «РискМенеджер-Анализ»....10

2.3. Построение моделей угроз и защиты с использованием системы «РискМенеджер-Анализ»....13

2.4. Построение моделей рисков нарушения информационной безопасности с использованием системы «РискМенеджер-Анализ»....16

2.5. Оценка рисков нарушения ИБ в системе «РискМенеджер-Анализ» и идентификация критических объектов и сегментов....19

2.6. Определение значимости мероприятий и мер обеспечения информационной безопасности в системе «РискМенеджер-Анализ»....21

2.7. Определение наиболее эффективного варианта комплекса мер повышения ИБ в системе «РискМенеджер-Анализ»....23

ПРИЛОЖЕНИЕ. ОСНОВНЫЕ СОКРАЩЕНИЯ....26

1. НАЗНАЧЕНИЕ ПРОГРАММЫ

Программный комплекс «РискМенеджер-Анализ» предназначен для построения моделей угроз, моделей защиты, проведения анализа возможных событий рисков и оценки рисков нарушения информационной безопасности автоматизированных информационных систем (АИС), построения вариантов комплексов мер по повышению безопасности АИС.

2. ОПИСАНИЕ ПРОГРАММЫ

ПК «РискМенеджер» позволяет строить структурные модели АИС, модели угроз и модели событий рисков, связанных с отдельными составляющими АИС и, таким образом, выявить те сегменты и объекты, риск нарушения безопасности которых является неприемлемым, то есть критическим. Помимо этого, ПК «РискМенеджер-Анализ» позволяет построить модель защиты - систему мер и требований, которые должны выполняться, что бы обеспечить безопасность АИС, а так же выработать оптимальный комплекс мероприятий по защите.

Построение структурной модели АИС в ПК "РискМенеджер-Анализ" осуществляется путем описания иерархической структуры АИС и идентификации объектов АИС в БД структурных моделей. Идентификация объектов выполняется путем указания их положения в структурной модели и определения их класса по списку справочной БД (СБД) классов объектов КЭС «РискМенеджер». Поэтому до построения структурной модели необходимо добиться полноты используемых СБД.

2.1. Базы данных ПК «РискМенеджер-Анализ»

Основная экспертная информация в системе «РискМенеджер» хранится в справочных базах данных. Именно в них накапливаются основные знания об угрозах, мерах и требованиях защиты АИС.

На рис. 2.1.1 представлена форма, отражающая основную концепцию построения СБД ПК «РискМенеджер-Анализ» и интерфейс доступа к данным.

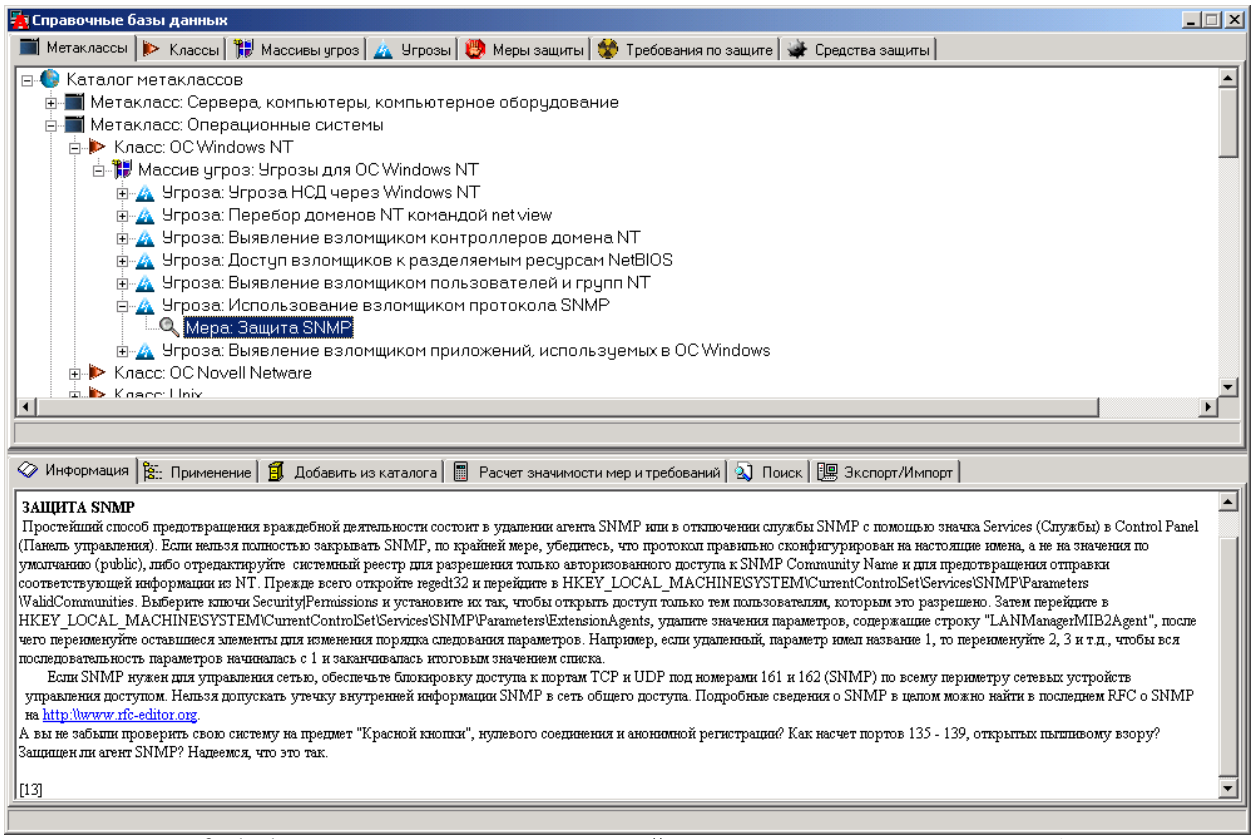


Рис. 2.1.1. Главная форма интерфейса доступа к справочным базам данных ПК «РискМенеджер-Анализ»

В ПК «РискМенеджер-Анализ» семь основных справочных БД: СБД метаклассов, СБД классов, СБД массивов угроз, СБД угроз, СБД мер защиты, СБД требований к защите, СБД средств защиты. Прямой доступ к перечню записей каждой из них можно получить воспользовавшись верхним набором закладок формы интерфейса.

СБД метаклассов является основой для обеспечения доступа к нужным классам.

Основным понятием в системе «РискМенеджер» является класс объекта. Именно путем указания класса идентифицируется любой новый объект в структурной модели АИС. Классы по тому или иному принципу схожести объединяются в метаклассы, таким образом, что бы облегчить ориентацию пользователя системы. Любой класс может входить в состав нескольких метаклассов. Изменение любой информации о классе в одном из метаклассов найдет отражение в БД, и, таким образом, будет отображаться при доступе к записи через любой из метаклассов, в который этот класс входит, или при доступе через перечень записей СБД классов.

СБД массивов угроз позволяет объединять отдельные угрозы в группы, с тем, что бы облегчить пользователю задачу определения угроз для классов объектов, когда речь идет о часто повторяющихся сериях одинаковых угроз для разных классов объектов. Как правило, такие группы угроз имеют и смысловое родство, например, «угрозы недостаточной подготовленности персонала» или «угрозы нарушения ИБ систем электронной почты».

СБД угроз содержит все известные угрозы нарушения ИБ АИС. Упорядочивание и классификация угроз производится путем их отнесения к определенному массиву угроз, и отнесением этого массива угроз к определенному классу объектов. Таким образом, одна и та же угроза может входить в несколько массивов угроз, и быть отнесена к нескольким классам объектов. Многие угрозы, относимые к тому или иному классу объекта, имеют условную составляющую. То

есть, они могут иметь место или не иметь его в отношении конкретного объекта, или, другими словами, могут быть значимыми или незначимыми для конкретного объекта данного класса в зависимости от того: обладает ли конкретный объект данного класса уязвимостями, которые могут привести к реализации указанных угроз для этого объекта; может ли в конкретных условиях существования объекта приниматься в расчет тот или иной источник угроз; может ли быть принята в расчет та или иная модель нарушителя или модель атак на объект. Итак, БД угроз по классам объектов построена таким образом, что в ней указываются все возможные угрозы для объектов каждого отдельно взятого класса. То, является ли угроза значимой, определяется в ходе построения и анализа моделей возможных событий рисков нарушения информационной безопасности АИС.

СБД мер защиты содержит информацию по всем известным мерам защиты от угроз, зарегистрированным в СБД угроз. При этом, естественно, не учитывается уровень защищенности конкретного объекта АИС, то есть то, что какие-то угрозы просто незначимы для конкретного объекта в силу того, что какие-то меры уже приняты. Значимость отдельных мер защиты для конкретного объекта определяется в результате построения и анализа моделей воздействия каждой из мер защиты по значимым угрозам на возможные события рисков.

СБД требований защиты содержит описание всех известных требований к защите средств и процессов информационных систем. Требования к защите сгруппированы и соотнесены с определенными мерами. В принципе одно и то же требование может быть в списке требований по самым разным мерам.

СБД средств защиты так же как и СБД требований защиты связаны с определенными мерами.

Работа по наполнению СБД, корректировке отдельных записей проводится с помощью контекстного (вызываемого, путем нажатия на правую кнопку мыши) меню. И хотя его содержание может соответствующим образом изменяться в зависимости от того на каком типе записей СБД установлен указатель просмотра (темная инверсирующая цвета полоска), тем не менее общий вид у них практически одинаков (см. рис. 2.1.2).



Рис. 2.1.2. Контекстное меню формы интерфейса справочных баз данных КЭС «РискМенеджер»

При достаточной очевидности основных функций в комментарии нуждаются только различия между функциями «Вставить» и «Вставить как шаблон», «Удалить» и «Удалить из каталога».

Выполнение функции «Вставить как шаблон» позволяет создать совершенно новую запись в СБД на основе существующей. При использовании функции «Вставить» новая запись не создается, а создается всего лишь ссылка на копируемую запись. Любая запись в СБД и более того вся связанная с ней структура записей иерархически подчиненных СБД может быть скопирована с тем, что бы потом вставить ее в какое-либо другое место иерархических связей записей СБД. Например, одна и та же мера защиты может быть указана таким образом для нескольких угроз. Такого рода операции осуществляются с помощью создания копии и простой вставки указанной записи.

Аналогично функция «Удалить» удаляет запись (по сути ссылку) только из той подструктуры, в которой она была указана, не затрагивая других подструктур, в

которые она входит. И более того, удаленная таким образом запись всегда может быть восстановлена в той подструктуре из которой она была удалена.

Функция «Удалить из каталога» удаляет запись из СБД без возможности ее последующего восстановления в какой-либо из подструктур. Прежде чем выполнять такого рода удаление необходимо убедиться в том, что эта запись больше не входит ни в одну из других подструктур. Как это сделать?

На рис. 2.1.1 видно, что помимо возможностей отследить иерархические связи между записями СБД и получить доступ к перечням записей в отдельных СБД, предоставляемых верхней частью формы, нижняя часть формы так же предоставляет ряд дополнительных возможностей, воспользоваться которыми можно с помощью еще одной группы закладок. Первая закладка - «Информация» дает возможность хранить и предоставлять любую (текстовую, графическую, аудио-, видео-) информацию о классе объекта, а так же ссылки на ресурсы в Интернете с возможностью моментального перехода на соответствующий интернет-ресурс при наличии онлайнового подключения к Интернет и установленного браузера. Выбор закладки «Применение» открывает доступ к возможности узнать в каких еще подструктурах используется указанная запись (Рис. 2.1.3). При необходимости с помощью контекстного меню можно удалить любую связь «вхождения» для любого из доступных уровней. Именно это нужно сделать перед удалением из СБД какой-либо записи, входящей в состав других записей СБД.

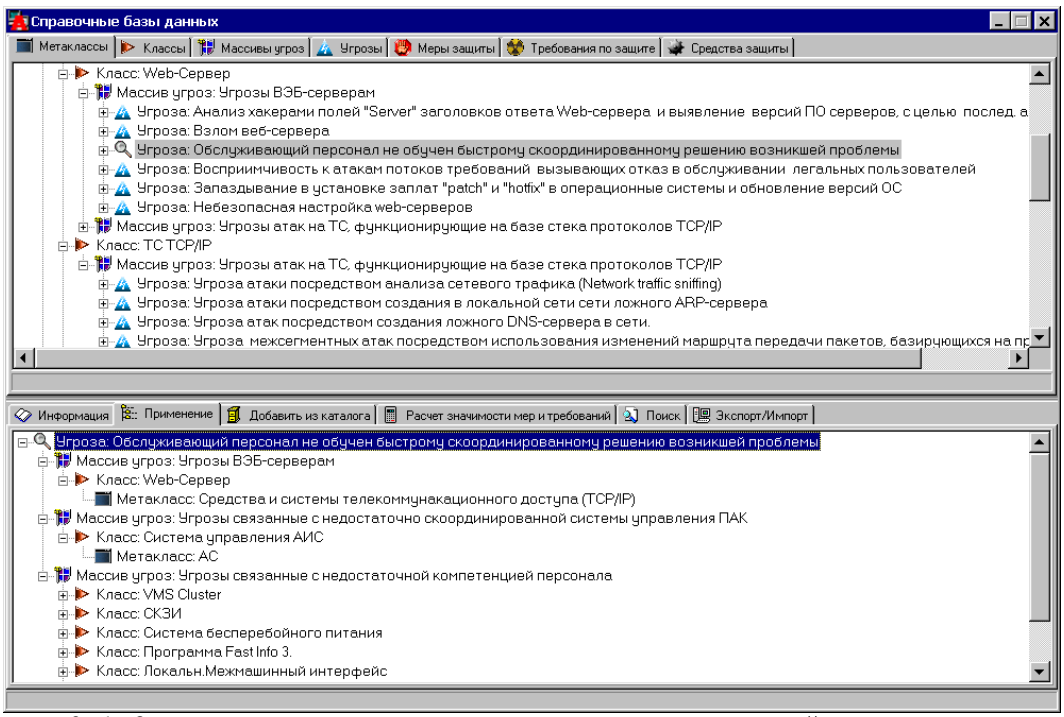


Рис. 2.1.3. Доступ к информации о применении записей СБД в различных структурах справочных БД

Выбор закладки «Добавить из каталога» в нижней части формы (рис. 2.1.4) позволяет пополнить перечень входящих в подструктуру записей (например, мер по угрозам) из общего списка записей соответствующей БД (например, БД мер защиты). Указание записи, которую нужно добавить осуществляется путем двойного клика левой кнопки мыши. Уже включенные в указанную подструктуру записи отсвечиваются в перечне доступных для включения записей СБД бледно желтым цветом. Под перечнем доступных для включения записей располагается поле представления текстовой и мультимедийной информации по той записи, на которой установлен указатель просмотра текущей записи БД.

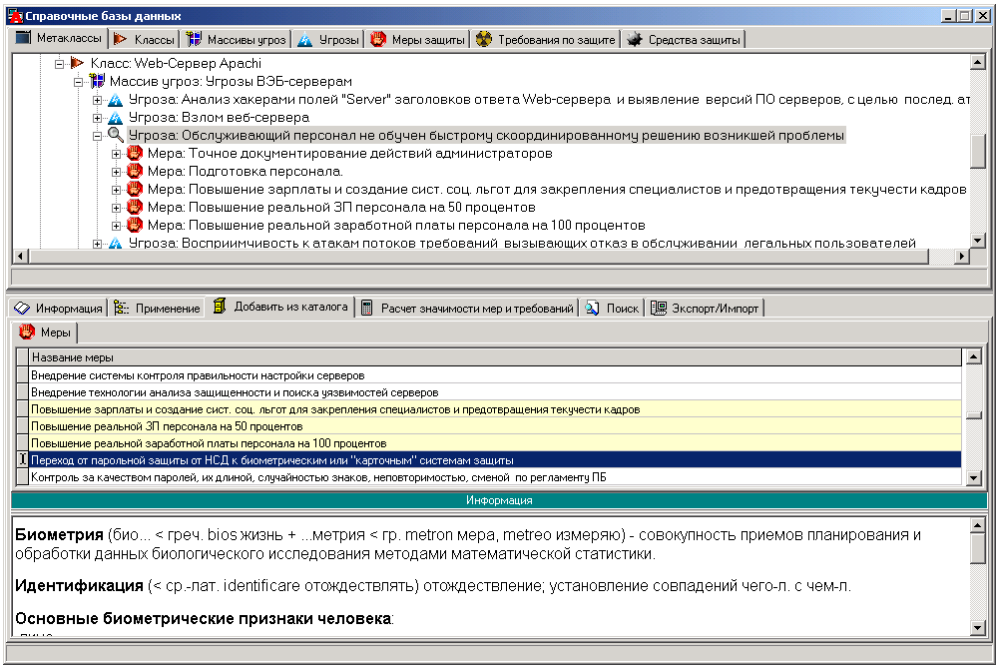


Рис. 2.1.4. Интерфейс для пополнения списка мер защиты по угрозе данными из каталога (БД) мер защиты

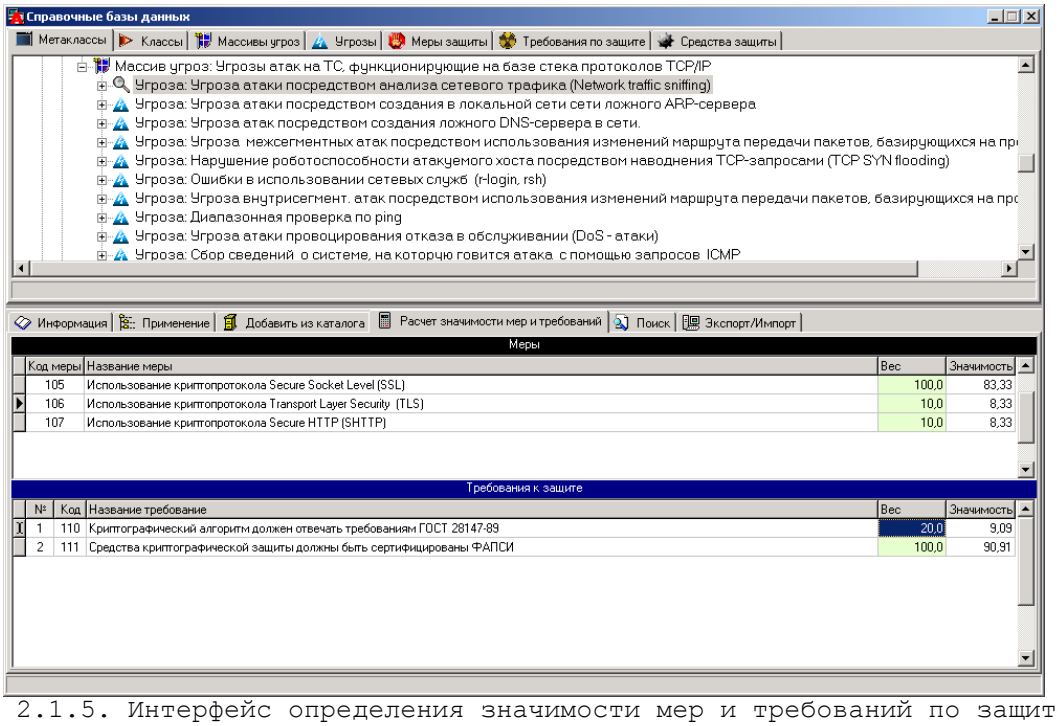


Рис. 2.1.5. Интерфейс определения значимости мер и требований по защите

Выбор закладки «Расчет значимости мер и требований» в нижней части формы (рис. 2.1.5) позволяет проставить по 100-балльной шкале оценки важности отдельных мер зашиты по отражению или предотвращению возможности реализации угрозы и оценки важности отдельных требований при реализации той или иной меры защиты. При этом автоматически рассчитываются коэффициенты значимости соответствующих составляющих. Общая сумма коэффициентов значимости компонентов любой подструктуры равна 100.

Расчет значимостей мер и требований не является обязательным в системе «РискМенеджер-Анализ». Полученные здесь данные значимости мер и требований могут использоваться в дальнейшем в комплексе «РискМенеджер-Контроль», после

конвертирования СБД системы «РискМенеджер-Анализ» в СБД системы «РискМенеджер-Контроль».

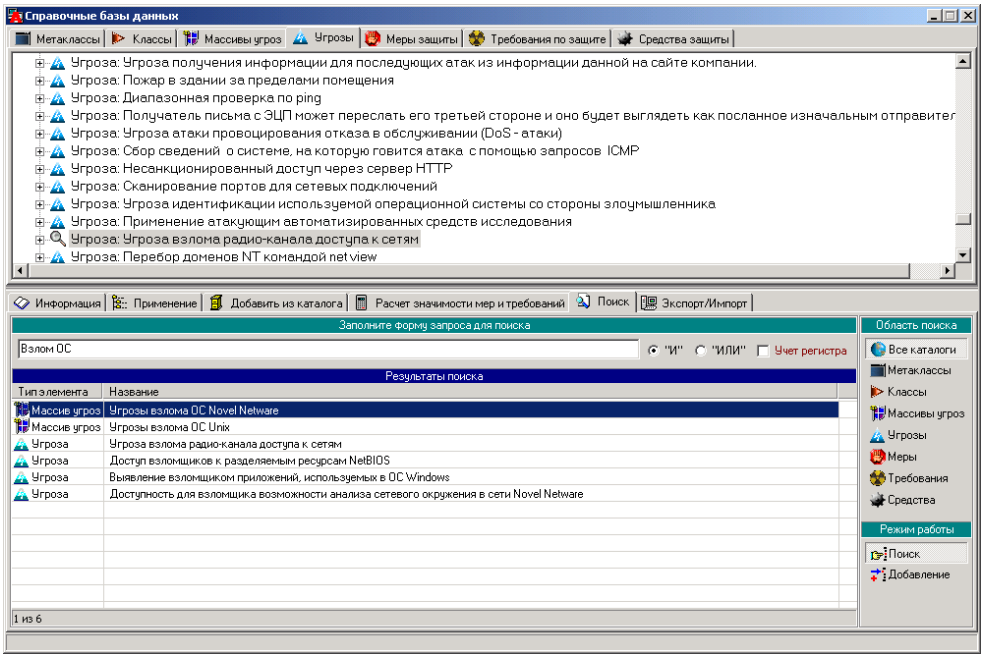


Рис. 2.1.6. Интерфейс поиска в базах данных

Выбор закладки «Поиск» в нижней части формы (рис. 2.1.6) дает возможность найти нужные записи в любой из БД по ключевым словам. Поиск можно делать по всем БД сразу или ограничить его, указав необходимую БД. Переход в режим «Добавление», путем нажатия кнопки в правом нижнем углу, делает доступным операцию добавления компонентов в любую из подструктур иерархического дерева баз данных, подобно тому, как это можно делать при работе с закладкой «Добавить из каталога».

Выбор закладки «Экспорт/Импорт» в нижней части формы (рис. 2.1.7) дает возможность экспортировать и импортировать БД. Реализация этой возможности в системе «РискМенеджер» позволяет, в частности, вести справочные базы данных на нескольких компьютерах. Для того, что бы дополнения, произведенные на одном компьютере стали доступны на другом, нужно на первом компьютере произвести операцию экспорта имеющихся на нем справочных БД, а на втором выполнить операцию импорта из того файла, что был тем или иным путем (на CD, дискете или через электронную почту) на него передан с первого компьютера.

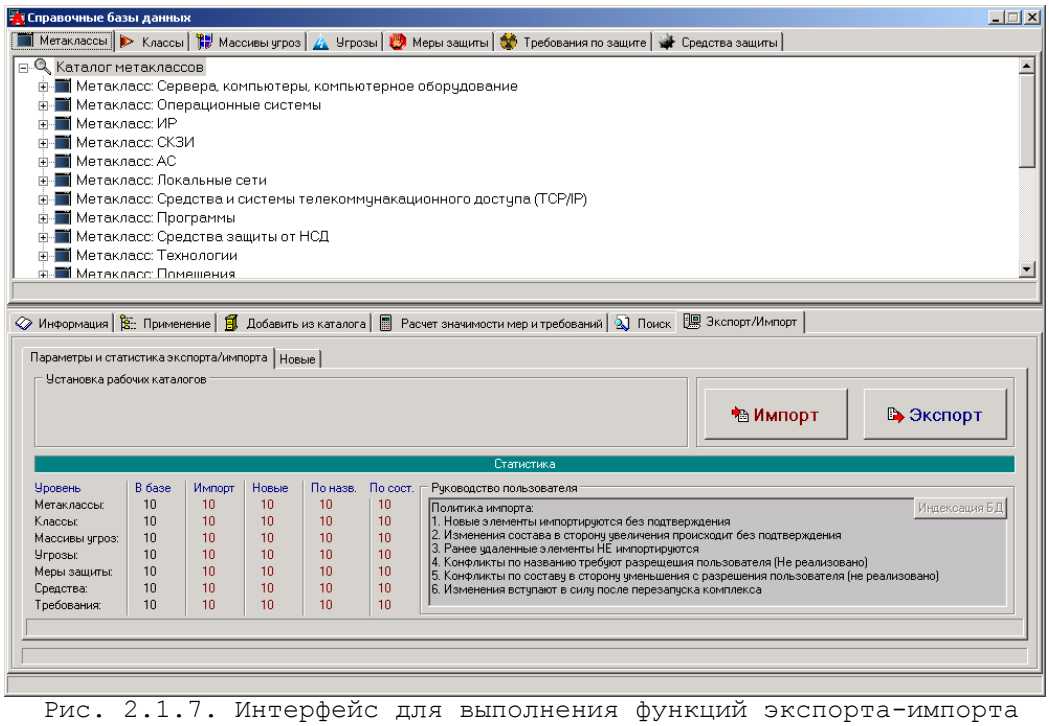


Рис. 2.1.7. Интерфейс для выполнения функций экспорта-импорта справочных баз данных

Таким образом, система «РискМенеджер-Анализ» обеспечена достаточно полным набором функциональных средств ведения справочных БД, что делает их поддержку в актуальном состоянии удобной и простой с технической точки зрения.

2.2. Построение структурной модели с использованием системы «РискМенеджер-Анализ»

Первой задачей, которая должна решаться в аналитическом процессе при управлении ИБ АИС - это построение структурной модели организации, с указанием в ней всего множества объектов по которым могут быть определены те или иные угрозы нарушения ИБ АИС. Каждый объект идентифицируется в структурной модели АИС путем фиксации его уникального названия и отнесения к тому или иному классу объектов, запись о котором содержится в СБД системы «РискМенеджер-Анализ».

Форма интерфейса, с помощью которой это делается, представлена на рис. 2.2.1.

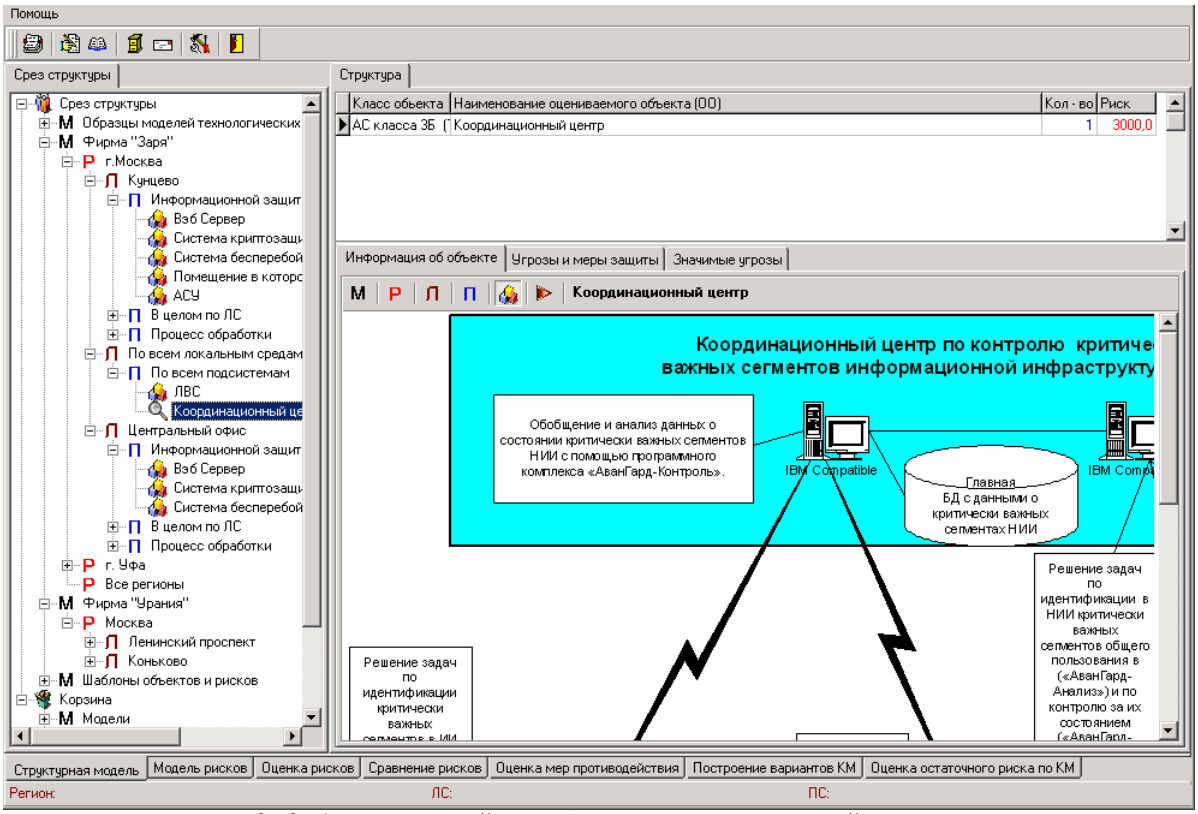


Рис. 2.2.1. Интерфейс работы со структурной моделью системы

Левая часть представленной формы содержит срез структуры управляемой системы. В правой расположена содержательная информация, связанная с теми или иными структурными составляющими.

Ведение БД структурной модели выполняется с помощью контекстного меню, общий вид которого представлен на рис. 2.2.2. В зависимости от того, какого типа подструктура добавляется (модель, регион, локальная среда, подсистема/процесс или объект) меняется только содержание первой строки меню, назначение функции связанной с которой, очевидно. Далее даны комментарии по тем опциям, функции которых не очевидны.

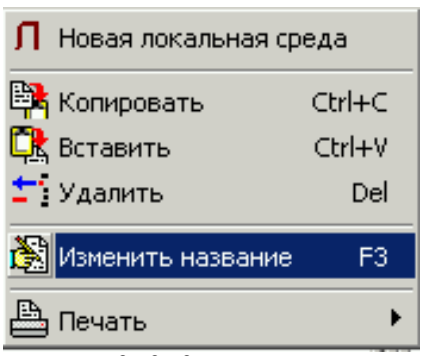


Рис. 2.2.2. Контекстное меню для ведения структурной модели

Опция «Копировать», дает возможность создать копию структуры любого уровня вместе со всеми входящими в нее подструктурами.

Соответственно, опция «Вставить» позволяет вставить скопированную структуру в указанное место, но только если оно адекватно ее уровню. Вместо указанных операций копирование объекта можно выполнить мышкой путем перетаскивания копируемой структуры в нужное место.

Выбор опции «Удалить» приводит к тому, что выбранная подструктура или объект будут удалены из той структуры, в которой они находились, и помещены в раздел «Корзина», находящийся в нижней части среза структуры. Из корзины любая подструктура может быть восстановлена в прежнее положение или скопирована в новое указанное для нее место. Удаление из корзины делает восстановление невозможным.

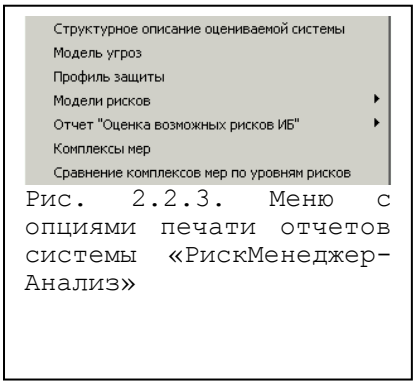


Рис. 2.2.3. Меню с опциями печати отчетов системы «РискМенеджер-Анализ»

Выбор опции «Печать» раскрывает меню с перечнем основных видов отчетов, которые могут быть получены. Выбор любой из опций меню печати дает возможность перейти к работе с интерфейсом окна предварительного просмотра (Print Preview) печатаемого отчета (рис. 2.2.4). Содержание отчета во многом будет зависеть от того, на какой из структур был установлен курсор (лупа) в срезе структуры. Отчет будет печататься по указанной структуре.

В режиме предварительного просмотра можно выбрать вид просмотра документа (первые три кнопки на верхней панели управления формы), осуществлять навигацию по печатаемому отчету (следующие 4 кнопки), произвести настройку принтера или указать диапазон печатаемых страниц (восьмая кнопка), пустить печать на принтер (девятая кнопка), сохранить печатаемую форму в файле (10 кнопка), открыть ранее сохраненную форму из файла (11 кнопка), закрыть форму предварительного просмотра и вернуться к форме работы с главной формой КЭС «РискМенеджер» (кнопка Close).

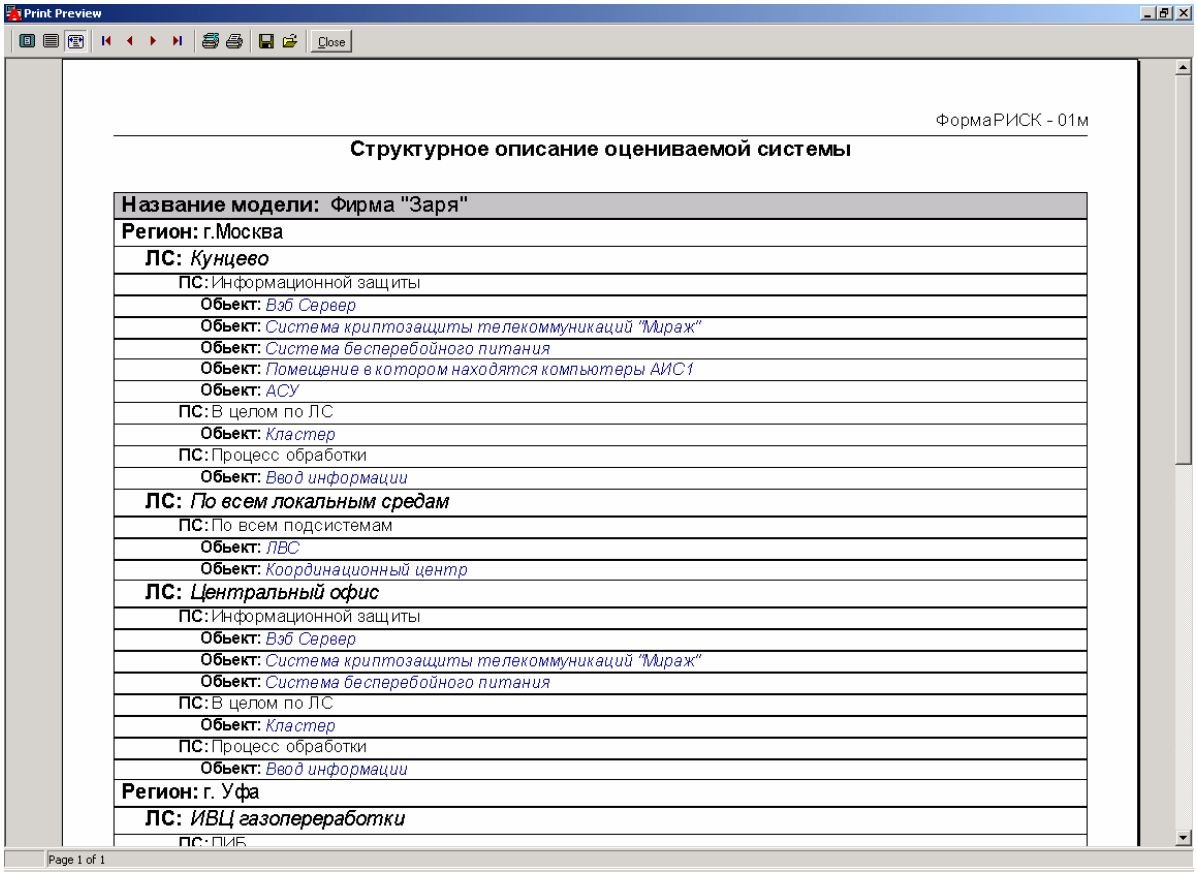


Рис. 2.2.4. Форма предварительного просмотра (Preview) печати отчетов КЭС «РискМенеджер»

Возвращаясь к главной форме (рис. 2.2.1), следует указать, что в режиме работы со структурной моделью в правой части расположена информационная часть, где отражаются данные по выбранной в дереве среза структуре. В верхней части окна располагается список объектов, входящих в указываемую структуру. В нижней, на закладке «Информация об объекте», дается информация неструктурированного типа, которая может содержать текстовые, графические и мультимедийные данные о соответствующей объекту модели (кнопка «М»), регионе (кнопка «Р»), локальной

среде (кнопка «Л»), подсистеме (кнопка «П»), самом объекте (предпоследняя кнопка), и наконец классе объекта (последняя кнопка).

2.3. Построение моделей угроз и защиты с использованием системы «РискМенеджер-Анализ»

Построение моделей угроз в системе «РискМенеджер-Анализ» производится автоматически. После того как тот или иной объект был идентифицирован в структурной модели путем отнесения его к некоторому классу, все угрозы известные для данного класса объектов и определенные для него в справочных базах данных рассматриваются как возможные угрозы для данного объекта. При работе с главной формой системы «РискМенеджер-Анализ» в режиме (на закладке) «Структурная модель» можно просмотреть информацию по всем угрозам по каждому из объектов оцениваемой системы. Соответственно вся совокупность угроз идентифицированных по объектам той или иной системы рассматривается как модель угроз соответствующей системы.

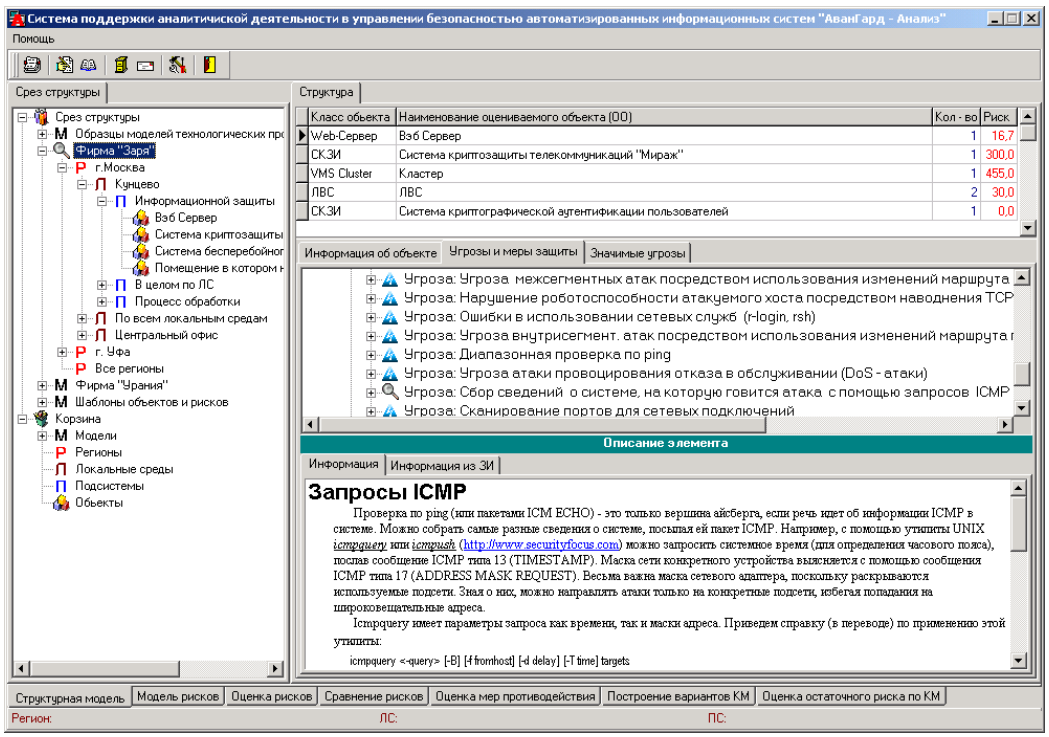


Рис. 2.3.1. Интерфейс доступа к данным модели угроз оцениваемой системы

Поскольку в СБД по каждому классу указываются все известные для данного класса объектов угрозы, с учетом всех возможных уязвимостей, и всех возможных моделей нарушителей и моделей атак, а по конкретному объекту те или иные уязвимости, типы нарушителей и атак могут не рассматриваться, в виду их отсутствия или невозможности реализации для конкретного объекта в конкретной среде, то полученную таким образом модель угроз предложено называть «нормативной», подлежащей рассмотрению на предмет возможности реализации входящих в нее угроз. Построение моделей событий рисков, проводимое с помощью системы «РискМенеджер-Анализ», позволяет определить опасность отдельных угроз и в результате сформировать модель значимых угроз для оцениваемой системы.

Нормативная модель может быть распечатана в виде представленном на рис. 2.3.2.

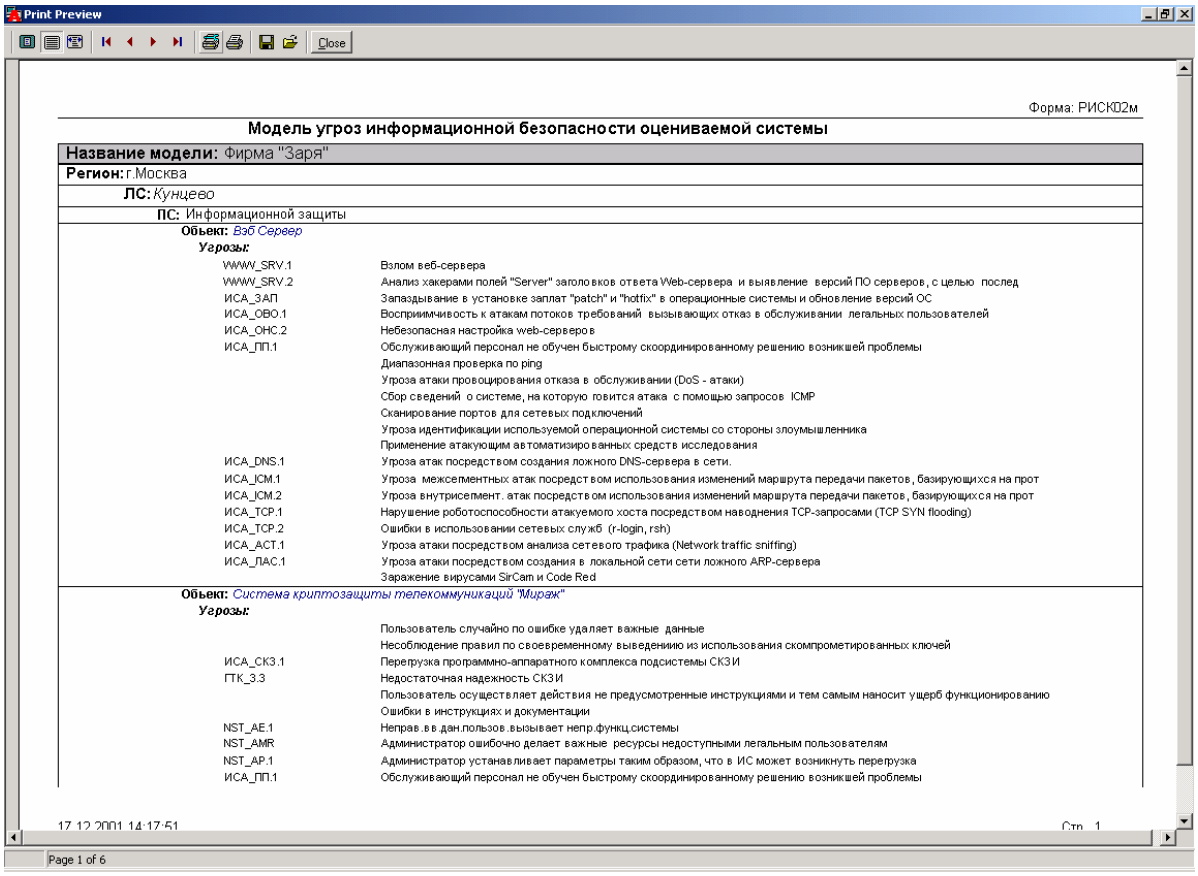


Рис. 2.3.2. Форма печати нормативной модели угроз оцениваемой системы

Аналогично, автоматически строится нормативная модель защиты, включающая в себя все известные и внесенные в СБД данные об известных мерах (методах, мероприятиях) защиты и требованиях по защите от каждой из известных угроз. Интерфейс доступа к информации о мерах и требованиях по защите по любому из объектов структурной модели оцениваемой системы представлен на рис. 2.3.2. Форма печати данных из модели защиты представлена на рис. 2.3.4. Так же как и модель угроз, модель защиты на этом этапе носит нормативный характер и включает перечень всех внесенных в СБД данных о мерах и требованиях защиты по каждой из известных угроз. Значимость отдельных мер определяется на последующих этапах анализа.

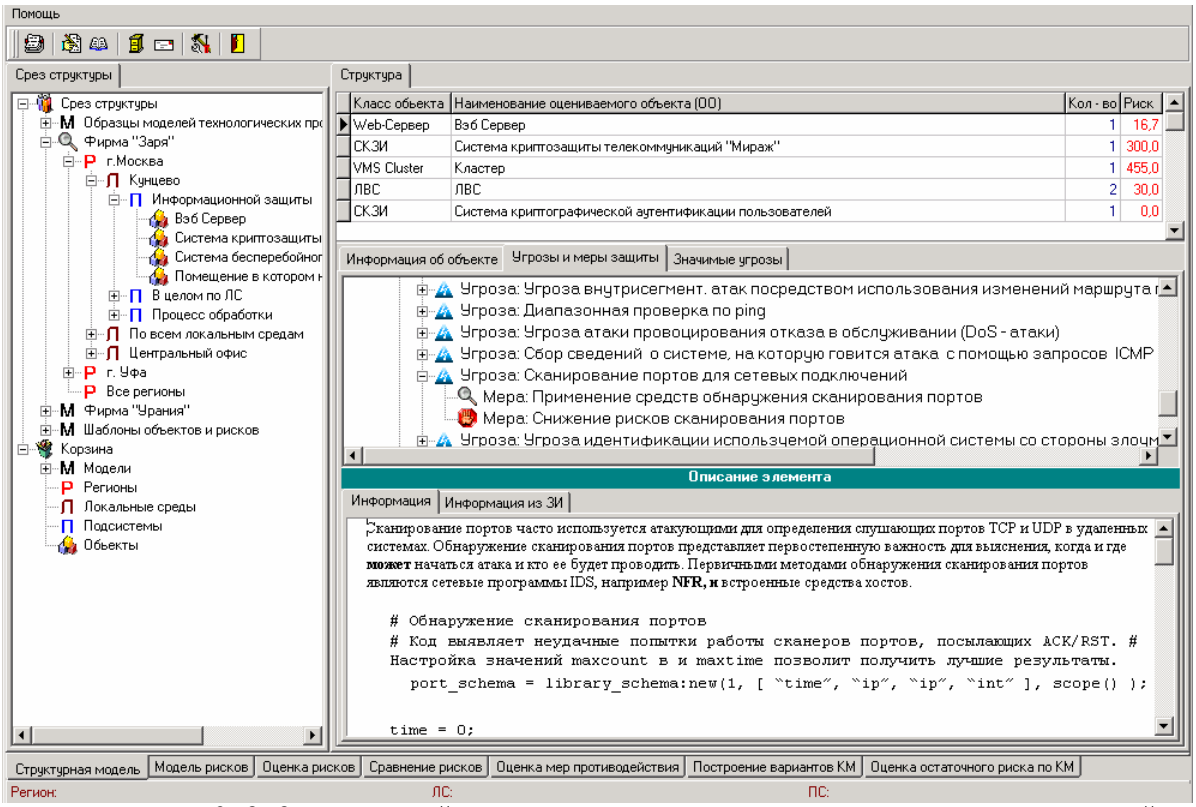


Рис. 2.3.3. Интерфейс доступа к данным модели защиты оцениваемой системы

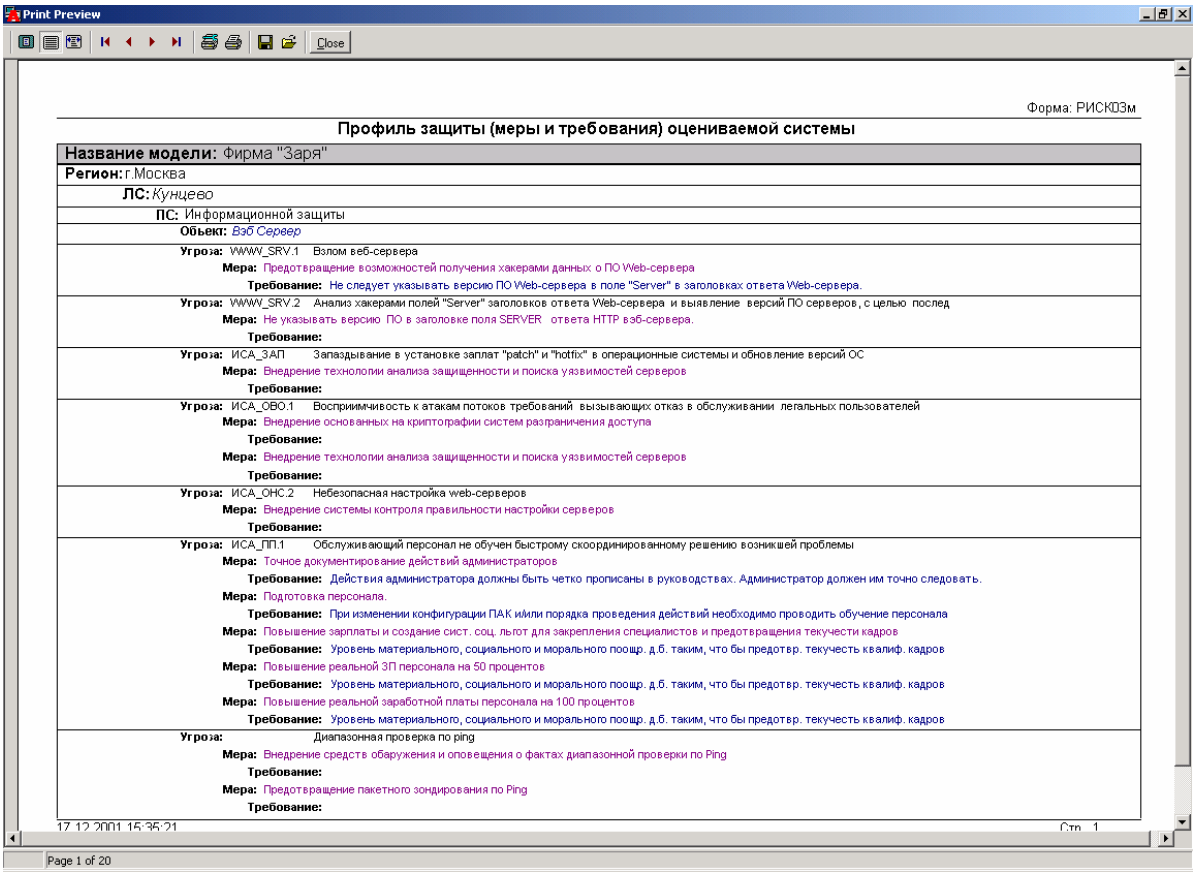


Рис. 2.3.4. Форма печати данных из модели защиты

2.4. Построение моделей событий рисков нарушения информационной безопасности с использованием системы «РискМенеджер-Анализ»

Для того, что бы определить реальность конкретных угроз из нормативной модели угроз необходимо провести анализ событий риска, которые могут произойти в результате их реализации. Построение моделей событий рисков выполняется с помощью интерфейса главной формы, вид которого представлен на рис. 2.4.1. Переход к работе с этим интерфейсом осуществляется путем выбора закладки «Модель рисков» в нижней части формы. Переход по этой закладке приводит к изменению правой, информационной, части формы. Рассмотрим смысл и содержание пяти секторов с информацией, представленных в этой части формы.

Самый верхний сектор содержит таблицу со списком моделей событий рисков, которые строятся пользователями. По каждой из моделей в соответствующих графах указываются экспертные оценки цены риска и вероятности события риска. Цена риска указывается в оценочных единицах. Если речь идет о материальном ущербе, то рекомендуется оценочной единице придавать конкретное ценовое значение. Например, 1 оценочная единица = 1000 рублей. Если речь идет о событиях риска, которые помимо материального ущерба, несут ущерб, который невозможно оценить в денежном выражении, то оценочные единицы рассматриваются как чисто балльные оценки для ранжирования событий риска по степени их опасности. Вероятность события риска указывается в процентах и не может превышать 100%. Если событие риска происходит чаще чем один раз в год, то в этом случае нужно в графе «Цена» показать среднегодовую оценку ущерба в оценочных единицах, соответственно в графе «Вероятность» должна указываться вероятность получения такого ущерба. В графе «Ущерб» показывается автоматически рассчитываемое значение величины риска, вычисляемое как произведение цены риска на вероятность события риска (значение графы «Вероятность», деленное на 100).

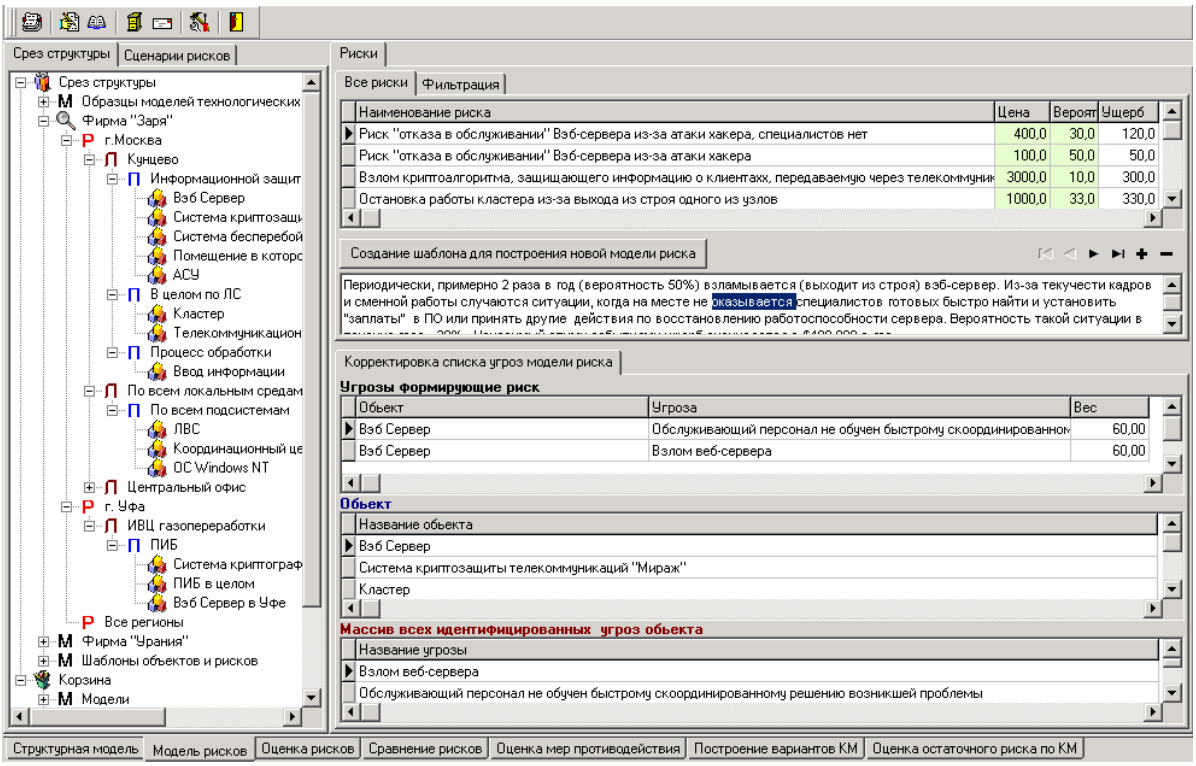


Рис. 2.4.1. Интерфейс построения моделей событий риска

В следующем секторе, расположенном под списком событий риска, находится поле с информацией о модели события риска. В нем должна быть дана как можно

более подробная информация о возможном событии риска и приведено объяснение проставленных экспертных оценок по цене риска и по вероятности этого события. Здесь следует рассмотреть и модель нарушителя и модели возможных атак с учетом имеющихся уязвимостей.

В следующем секторе представлена таблица угроз, одновременная реализация которых может привести к событию риска с указываемыми вероятностью и ценой риска. По каждой из угроз показывается оценка веса каждой из угроз в событии риска (рискообразующий потенциал угрозы по событию риска). В рамках аксиоматики, на которой построена система «РискМенеджер», предполагается, что вес всех угроз, порождающих событие риска в рамках данной модели, одинаков. Без любой из них данная модель события риска перестает существовать и событие риска либо вообще не происходит, либо происходит в рамках иной модели с другими оценками цены риска и/или вероятности события риска. Поэтому оценка веса каждой из угроз, входящих в модель рассчитывается путем деления ожидаемого ущерба (величины риска) по событию риска на количество угроз, в результате реализации которых это событие риска происходит.

Два, расположенных внизу формы сектора, дают возможность при построении модели события риска ввести в нее угрозы, в результате реализации которых это событие риска происходит. Первый дает возможность выбрать объект, угрозы по которому следует рассмотреть, а во втором отображаются угрозы по указанному объекту. Для того, что бы добавить угрозу в модель события риска достаточно установить указатель мыши на нужную угрозу и дважды щелкнуть левой кнопкой мыши.

При построении новых моделей событий рисков можно пользоваться готовыми моделями как шаблонами. Для этого следует установить курсор на нужную модель риска и нажать кнопку «Создание шаблона для новой модели риска». После чего курсор в списке моделей риска будет установлен на новую модель созданную путем копирования исходной модели. В полученной таким образом копии можно все менять по своему усмотрению: добавлять, или удалять угрозы из списка, корректировать значения оценок вероятности и цены риска, корректировать описание события риска.

Система предоставляет возможность так же вести базу шаблонов моделей рисков по объектам и более крупным структурным составляющим. В качестве шаблонов могут использоваться любые структурные составляющие, идентифицированные в структурной модели, а так же те, что выделены в специальной модели структурного среза, предназначенной для хранения типовых шаблонов. В случае использования таких шаблонов новые объекты создаются не через идентификацию их классов с помощью БД классов объектов, а путем создания их в виде копий готовых шаблонов. Таким образом, можно определять не просто отдельные объекты, а целые совокупности объектов и составляющих более высокого уровня, а вместе с ними и модели событий рисков с ними связанных.

Представленный интерфейс при использовании закладки «Фильтрация» (в правой части формы) дает возможность так же фильтровать, то есть рассматривать по частям, множества моделей рисков в зависимости от структурной составляющей с которой связаны угрозы, вошедшие в указанную модель риска. При этом действуют следующие правила. Если модель риска включает угрозы только по одному объекту, то соответствующая модель риска показывается при установке курсора в срезе структуры на соответствующий объект, или на любой из сегментов структуры в который входит этот объект. Если модель риска включает угрозы по нескольким объектам одной подсистемы, то соответствующая модель риска показывается при установке курсора в срезе структуры на соответствующую подсистему, или на любой сегмент структуры, в который входит эта подсистема. Если модель риска включает угрозы по нескольким объектам из разных подсистем одной локальной среды, то

соответствующая модель риска показывается при установке курсора в срезе структуры на соответствующую локальную среду, или на любой сегмент структуры, в которую входит эта локальная среда. Если модель риска включает угрозы по нескольким объектам разных локальных сред в рамках одного региона, то соответствующая модель риска показывается при установке курсора в срезе структуры на соответствующий регион, и по модели в целом. Если модель риска включает угрозы по нескольким объектам из разных регионов, то соответствующая модель риска показывается при установке курсора в срезе структуры только на ту модель, в рамках которой рассматриваются указанные регионы.

Указанные правила действуют и при копировании моделей событий рисков в процессе копирования отдельных объектов или сегментов структурного среза, когда уже описанные в рамках структуры объекты или сегменты используются в качестве шаблонов для описания новых структурных составляющих. Если копируется объект, то вместе с ним копируются модели только тех событий рисков, которые происходят в результате реализации угроз только по данному объекту и ни по какому другому больше. Если копируется подсистема, вместе с ней копируются модели только тех событий рисков, которые происходят в результате реализации угроз только по объектам данной подсистемы и никакой другой больше. Если копируется локальная среда, вместе с ней копируются модели только тех событий рисков, которые происходят в результате реализации угроз только по объектам данной локальной среды и никакой другой больше. Если копируется регион, вместе с ним копируются модели только тех событий рисков, которые происходят в результате реализации угроз только по объектам данного региона и никакого другого больше. Если копируется модель среза структуры (СС), вместе с ней копируются модели только тех событий рисков, которые происходят в результате реализации угроз только по объектам данной модели СС.

Следует упомянуть и о еще одной возможности, которая может оказаться полезной при работе с моделями рисков. Эта возможность становится доступна, если в левой части формы выбрать закладку «Сценарии рисков». С ее помощью можно отслеживать возможное развитие моделей событий рисков при причинно-следственной реализации нарастающего количества угроз. Эта возможность иллюстрируется на рисунке 8.2.

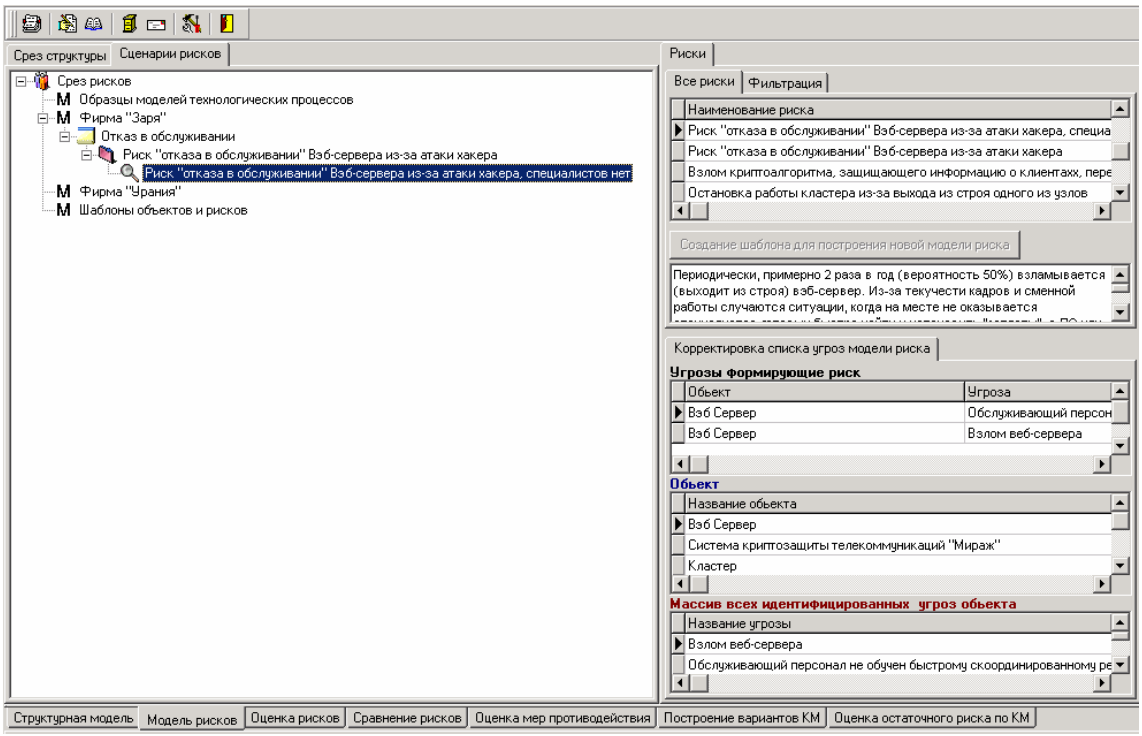


Рис. 2.4.2. Интерфейс отслеживания сценариев развития моделей событий рисков

2.5. Оценка рисков нарушения ИБ в системе «РискМенеджер-Анализ» и идентификация критических объектов и сегментов

На основе оценок значимости отдельных угроз, полученных при моделировании событий рисков, можно определить в какой степени риски соотносятся с конкретными объектами и другими структурными составляющими оцениваемой системы. При этом необходимо помнить, что любая угроза в рамках структурной модели идентифицируется не только своим названием и своей идентификацией в СБД угроз, но и объектом, с которым она связана. Таким образом, угроза идентифицированная в СБД угроз одной записью при ее указании для двух различных объектов структурной модели будет представлять собой две абсолютно разные угрозы. При определении веса такого рода угрозы (то есть угрозы связанной с конкретным объектом), с учетом ее возможно многократного вхождения в различные модели рисков, в качестве окончательного значения значимости угрозы всегда берется максимальное значение ее веса (рискообразующего потенциала) во всем множестве моделей событий риска.

Определение размера рисков по объектам, подсистемам/процессам, локальным средам, регионам и по модели в целом, производится путем суммирования показателей значимостей угроз относимых в рамках структурной иерархической модели к соответствующим структурам. То есть, размер риска по объекту (рискообразующий потенциал объекта) будет равен сумме рискообразующих потенциалов угроз с ним связанных. Рискообразующий потенциал подсистемы/процесса будет равен сумме рискообразующих потенциалов, включенных в нее объектов. При этом, для того, что бы определить рискообразующий потенциал, связанный с угрозами, относимыми к подсистеме/процессу в целом, в структурной модели может быть определен виртуальный объект типа «По подсистеме/процессу в целом». Рискообразующий

потенциал локальной среды будет равен сумме рискообразующих потенциалов подсистем/процессов, входящих в эту локальную среду. При этом, для того, что бы определить рискообразующий потенциал, связанный с угрозами, относимыми к локальной среде в целом, в структурной модели может быть определена виртуальная цепочка состоящая из подсистемы и объекта типа «По локальной среде в целом». Рискообразующий потенциал региона будет равен сумме рискообразующих потенциалов локальных сред, находящихся в этом регионе. При этом, для того, что бы определить рискообразующий потенциал, связанный с угрозами, относимыми к региону в целом, в структурной модели может быть определена цепочка виртуальных подструктур типа «По региону в целом». Рискообразующий потенциал по модели системы будет равна сумме рискообразующих потенциалов регионов, определенных в данной модели системы. При этом, для того, что бы определить рискообразующий потенциал, связанный с угрозами, относимыми к модели системы в целом, в структурной модели может быть определена цепочка виртуальных подструктур типа «По модели системы в целом».

Результат полученных вычислений выдается на экран компьютера пользователя в виде, представленном на рис. 2.5.1, или на печать в виде отчета (рис. 2.5.2). Помимо этого комплекс позволяет произвести сравнение по размеру риска (рискообразующему потенциалу) любых составляющих одного иерархического уровня из любых моделей. Для этого нужно в нижнем блоке закладок формы выбрать опцию «Сравнение рисков». Затем указать уровень (объекты, подсистемы, локальные среды, регионы, модели) на котором будет проводиться сравнение, а потом из среза структуры (двойным кликом) выбрать сравниваемые составляющие.

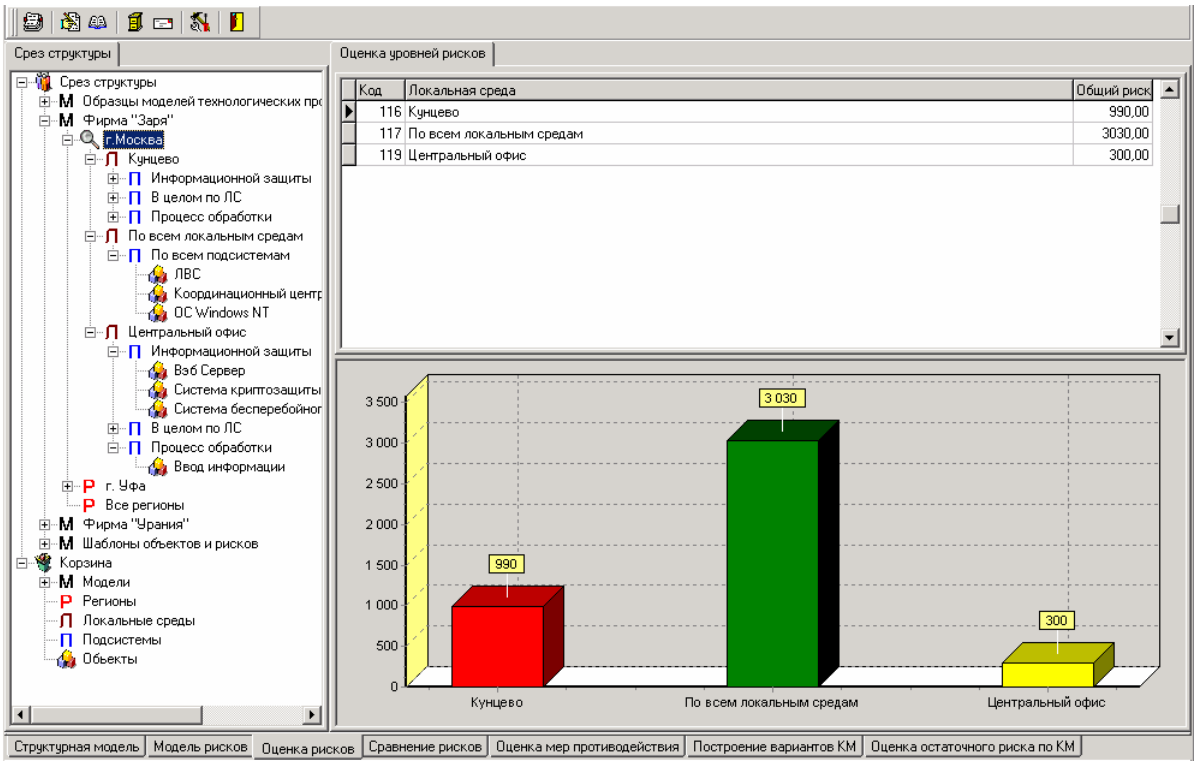


Рис. 2.5.1. Форма представления оценок рисков нарушения информационной безопасности по отдельным объектам и сегментам (в данном случае по локальным средам) структурной модели

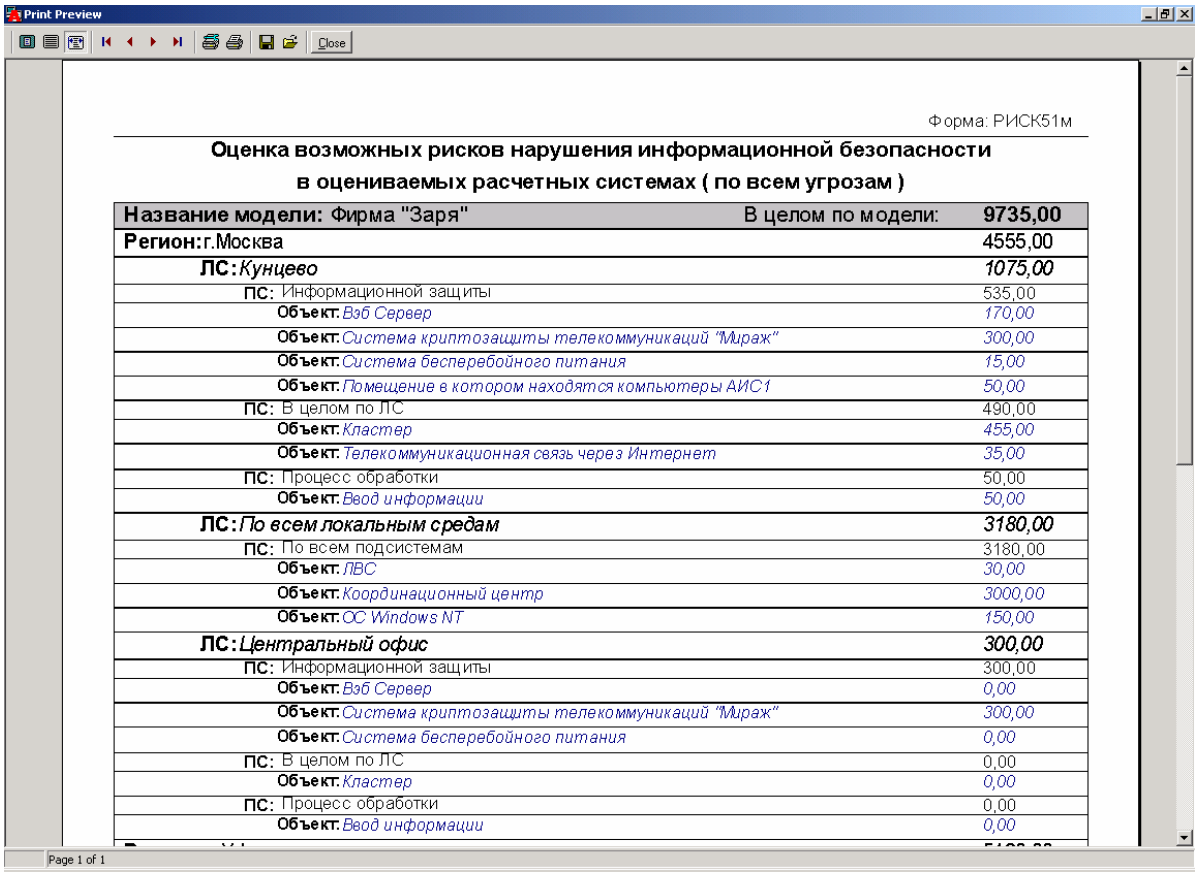


Рис. 2.5.2. Форма отчета, представляющего оценки размеров риска нарушения информационной безопасности

Использование выходных данных с оценками рисков по структурным составляющим дает возможность идентифицировать основные рискообразующие объекты и сегменты оцениваемой системы. Именно они являются основными критически важными (критическими) составляющими оцениваемой системы, именно по ним необходимо обеспечить контроль выполнения мер и требований по защите АИС.

2.6. Определение значимости мероприятий и мер обеспечения информационной безопасности в системе «РискМенеджер-Анализ»

Для определения значимости отдельных мер и мероприятий по защите от угроз, пользователям системы «РискМенеджер-Анализ» предлагается с помощью интерфейса представленного на рис. 2.6.1 определить возможности понижения риска (цены и вероятности отдельных событий) при принятии каждой из мер, определенных в модели защиты. Переход к указанному интерфейсу осуществляется путем выбора закладки «Оценка мер противодействия» в нижнем блоке закладок главного окна. В правой части указанного интерфейса верхние три окошечка содержат данные по модели риска. Таблица рисков, в основном аналогична той, что была представлена в интерфейсе построения моделей рисков, за исключением того, что добавлена графа «Остаток», которая позволяет контролировать полноту определения значимости мер по угрозам каждой из моделей риска. В этой графе указывается величина риска, которая осталась непокрытой, мерами защиты. Если по модели риска ни по одной из возможных мер не определена ее значимость, то величина «непокрытого» риска высвечивается красным цветом. Сразу под таблицей

моделей рисков расположено окно описания события риска и под ним список угроз формирующих событие риска. В следующей таблице, в соответствии с концепцией построения модели защиты, по каждой угрозе указывается перечень мер и мероприятий, с помощью которых указанной угрозе можно противодействовать. Задача пользователя состоит в том, что бы по каждой мере, по которой это возможно, указать новые значения цены риска и вероятности события риска, в случае, если эта мера будет принята. При этом, может приниматься во внимание тот факт, что рассматриваемая мера наибольший эффект может дать, если будет применяться в комплексе с другими мерами, однако в дальнейшем это должно быть учтено при формировании соответствующего варианта комплекса мер (комплексы мер строятся на следующем этапе работы с системой «РискМенеджер-Анализ»).

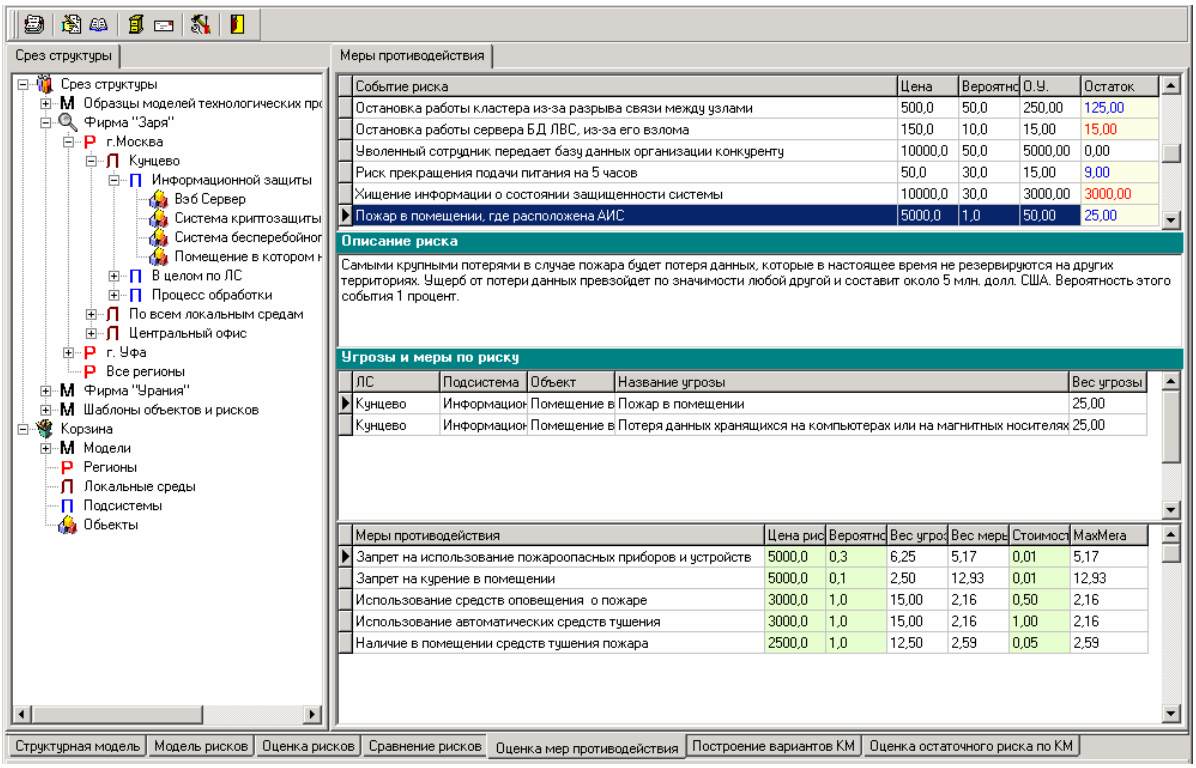


Рис. 2.6.1. Интерфейс определения значимости отдельных мер (мероприятий) по защите от угроз

Те колонки, которые может заполнять пользователь в таблице мер противодействия подсвечены зеленоватым цветом. Помимо новых (ожидаемых) значений цены риска и вероятности события риска, пользователь может указать стоимость указанного мероприятия или меры исходя, как правило, из годовых расходов на их реализацию.

Содержание других колонок следующее:

В колонке «Вес угрозы», показывается рассчитанное новое значение веса угрозы (рискообразующего потенциала угрозы по событию риска), которое она будет иметь в случае реализации меры.

В колонке «Вес меры» показывается рассчитанное значение веса меры (ее рископонижающего потенциала).

2.7. Определение наиболее эффективного варианта комплекса мер повышения ИБ в системе «РискМенеджер-Анализ»

Выбор закладки «Построение вариантов комплексов мер (КМ)» в главном окне системы «РискМенеджер-Анализ» делает доступной форму интерфейса, с помощью которой можно строить различные варианты комплексов мер и сравнивать их между собой по критерию «эффективность-стоимость» (рис. 2.7.1).

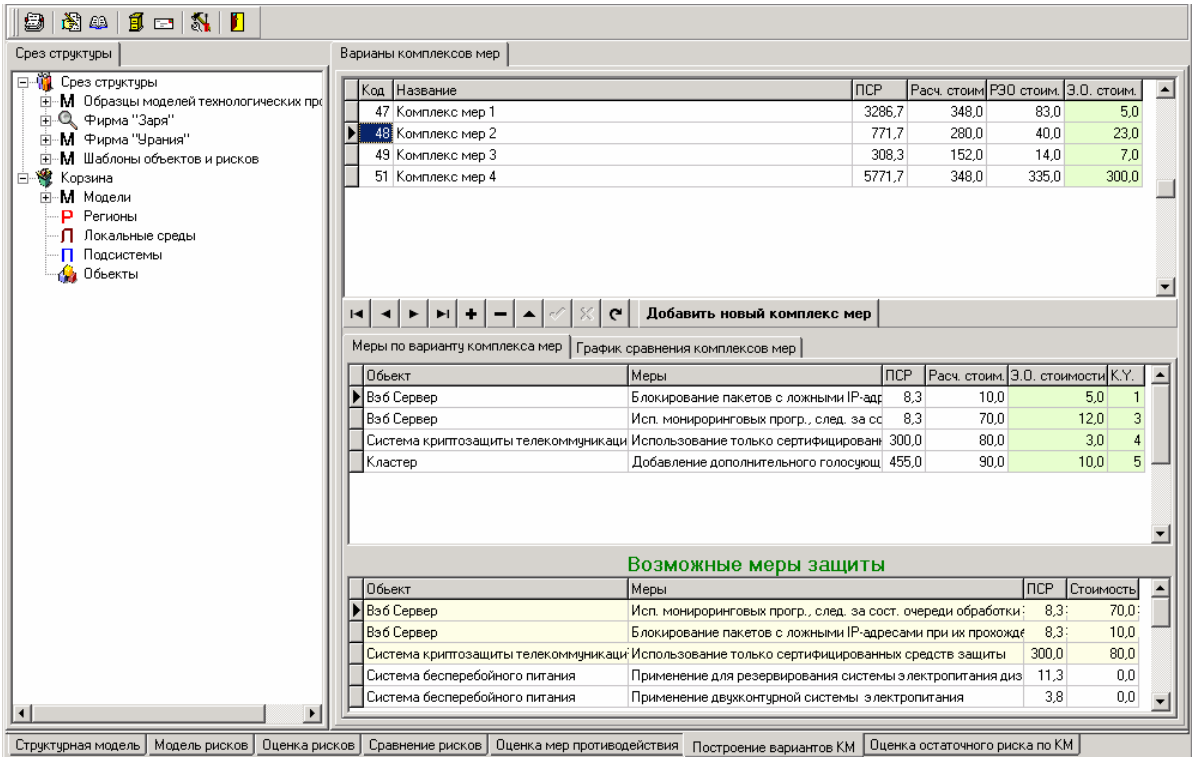


Рис. 2.7.1. Интерфейс построения вариантов комплексов мер

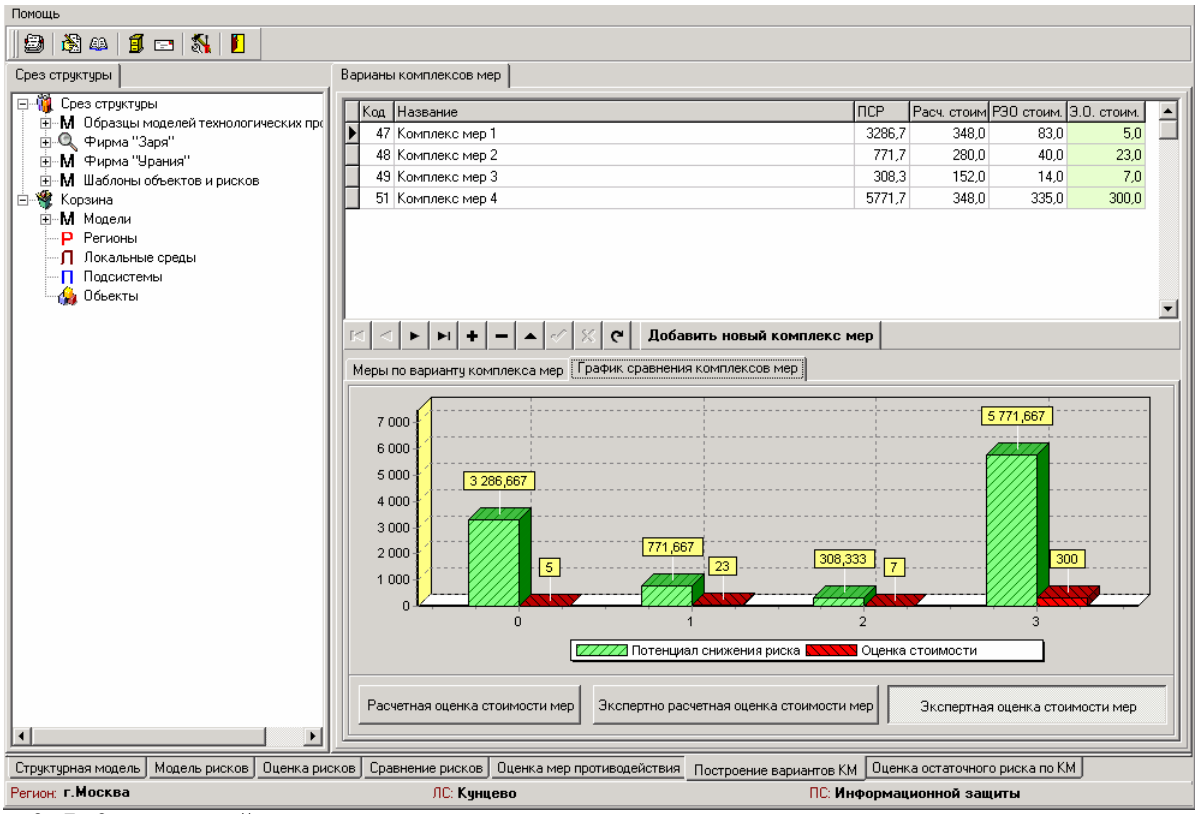
Построение комплекса мер в системе «РискМенеджер-Анализ» начинается с нажатия на кнопку «Добавить новый комплекс мер». После этого предлагается ввести название нового комплекса мер и, используя срез структуры в качестве указателя необходимых объектов и таблицу «Возможные меры защиты», добавить необходимые записи в таблицу «Меры по варианту комплекса мер». Добавление производится путем двойного щелчка левой кнопкой мыши на нужной записи в таблице «Возможные меры защиты». Выбранные в рамках данного комплекса меры выделяются в нижней таблице бледно желтой подцветкой соответствующих строк.

Отметим, что в таблицу «Возможные меры защиты» попадают только значимые меры, то есть только те меры, по которым на предыдущем шаге анализа было выявлено, что они позволяют снизить риски нарушения ИБ.

Сравнение вариантов комплексов мер (КМ) проводится с помощью использования закладки «График сравнения комплексов мер» (рис. 2.7.2).

Дополнительную информацию для определения наилучшего комплекса мер можно получить выбрав в нижнем блоке закладок главного окна системы «РискМенеджер-Анализ», опцию «Оценка остаточного риска по КМ» (рис. 2.7.3).

Информацию о комплексах мер можно распечатать в виде представленном на рис. 2.7.4, 2.7.5. Кроме того, могут быть выданы на печать все необходимые графики.



2.7.2 Интерфейс оценки и сравнения вариантов комплексов мер по критерию «эффективность-стоимость»

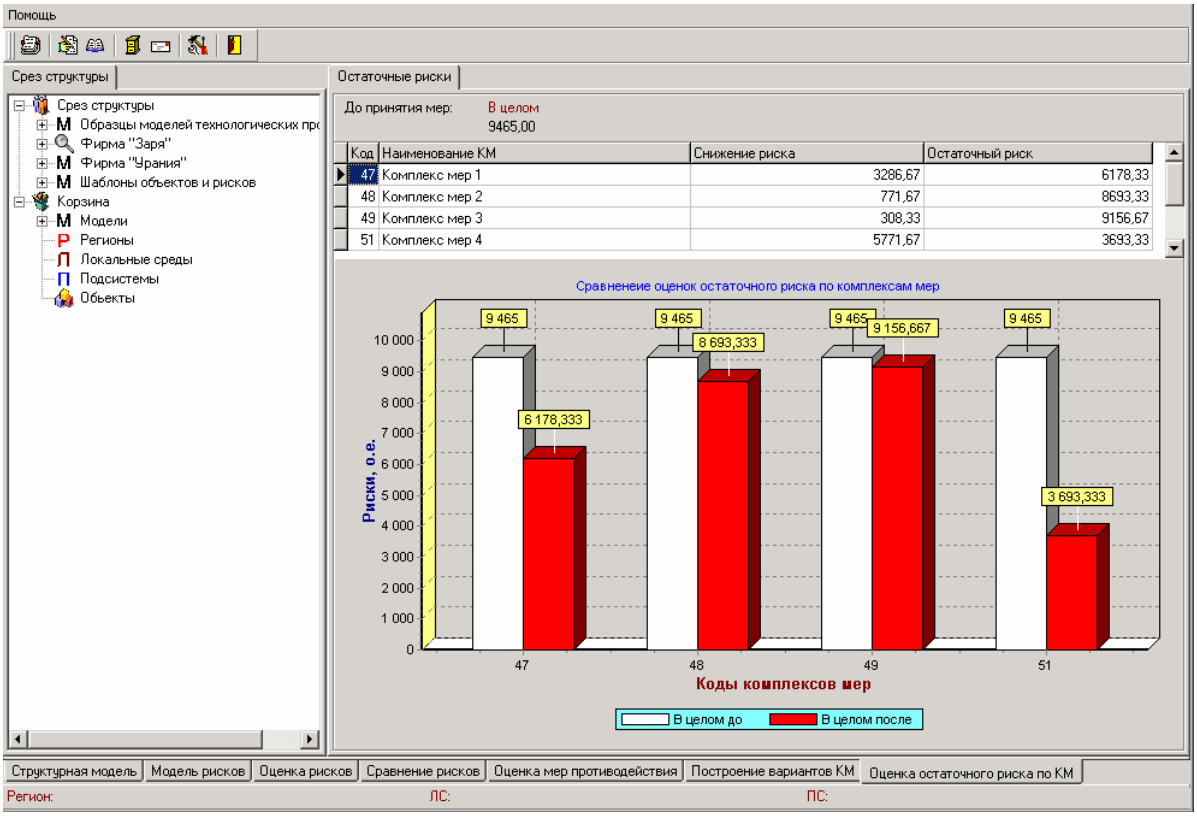


Рис. 2.7.3. Оценка остаточных рисков

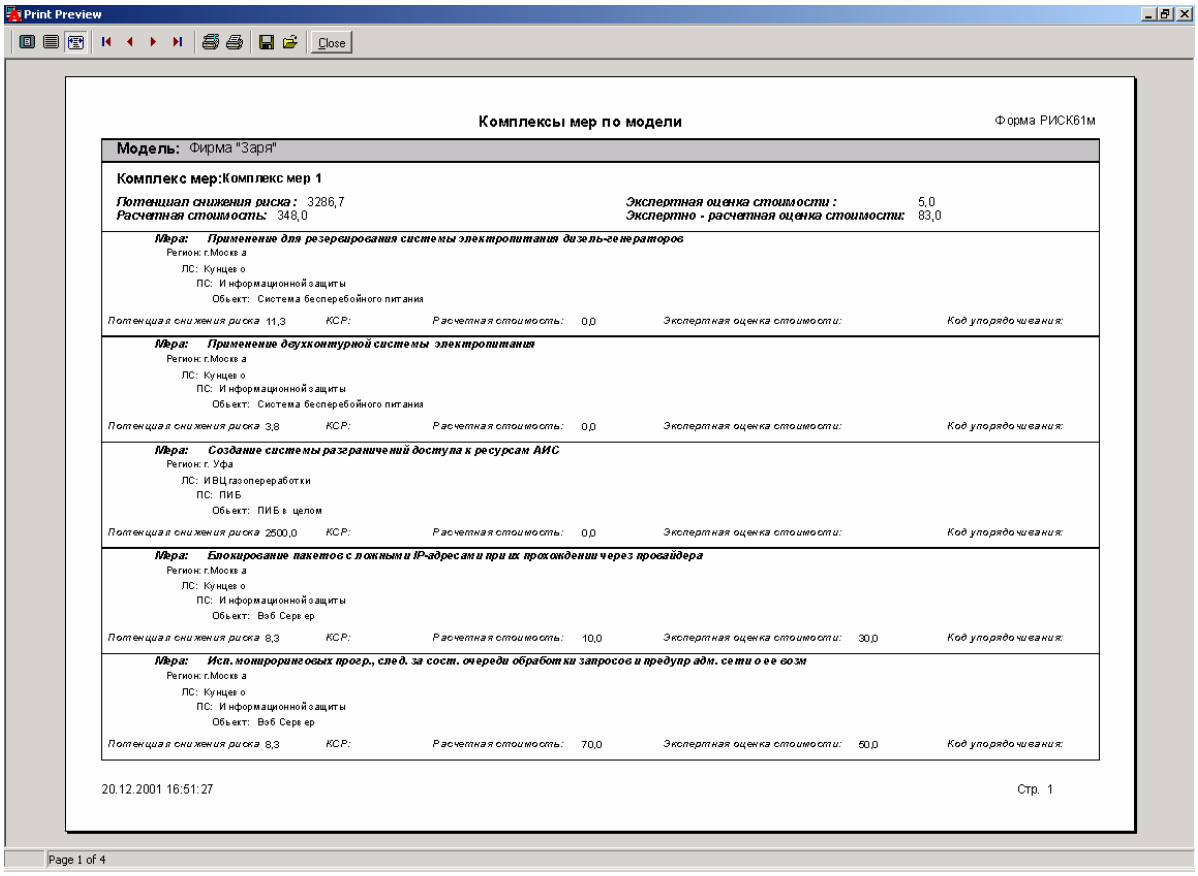


Рис. 2.7.4. Вид формы предварительного просмотра отчета по комплексам мер

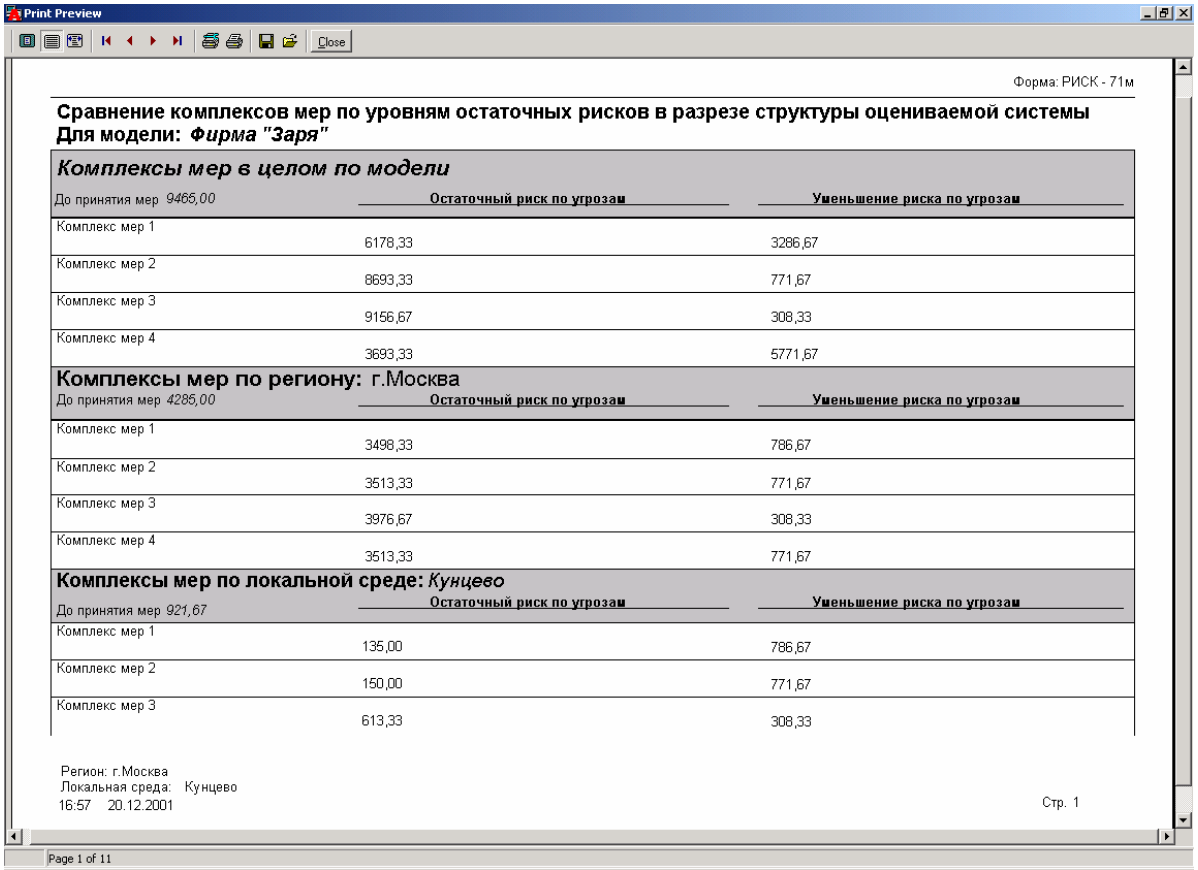


Рис. 2.7.5. Вид формы предварительного просмотра отчета сравнения остаточных рисков по комплексам мер

ПРИЛОЖЕНИЕ. ОСНОВНЫЕ СОКРАЩЕНИЯ

АИС – автоматизированная информационная система;
БД – база данных;
ИБ – информационная безопасность;
ИС – информационная система;
СБД – справочная база данных;
ИТ – информационная технология;
КМ – комплекс мер;
НИР – научно-исследовательская работа;
ПО – программное обеспечение;
ПД – программная документация;
ПК – программный комплекс;
ТЗ – техническое задание.

Лист регистрации изменений									
Номера листов (страниц)					Всего листов (страниц) в докум.	№ документа	Входящий № сопроводи-тельного документа и дата	Подпись.	Дата
Изм	измененных	замененных	новых	аннулиро-ванных					